Pass The Ticket - Depuis Linux

Bien que peux courant les ordinateurs Linux peuvent se connecter à Active Directory, un tel ordinateur utilise généralement Kerberos pour l'authentification. Un system linux peux être configurer de diverses manière pour stocker les tickets Kerberos.

Dans la plupart des cas les machines linux stockent les tickets Kerberos sous forme de fichier ccache dans /tmp. Par défault l'emplacement du ticket Kerberos est stocké dans la variable d'environnement KRB5CCNAME, Une autre utilisation courante sous linux se fait avec des fichiers keytab. Un keytab est un fichier contenant des paires de principaux Kerberos et de clés chiffrées (qui sont dérivées du KDP Kerberos)

- On peux identifier si une machine linux est jointe au domaine en utilisant realm un outil utilisé pour gérer l'adhésion du system à un domaine et autre joyeuseté. D'autres outils peuvent êtres utilisés comme sssd ou winbind.

```
david@inlanfreight.htb@linux01 ~$ realm list
inlanfreight.htb
  type: kerberos  etc
```

Trouver les Tickets: En tant qu'attaquant nous voulons trouver les tickets Kerberos pour obtenir plus d'accès. On peux par exemple utiliser find pour localiser de potentiels fichiers keytab

```
david@inlanfreight.htb@linux01 ~$ find / -name *keytab* -ls 2>/dev/
```

On peux également regarder la variable d'environnement krb5:
`~$ env | grep -i krb5` (le -i ignore la casse)
On peux également lister les fichier dans /tmp à la recherche de fichier cache encore valid.

Abuser des fichiers keytab:

En tant qu'attaquant on peux avoir plusieurs usages pour un fichier keytab. La première chose que l'on peu faire est d'usurper l'identité d'un utilisateur avec kinit (outil principal permettant de s'authentifier auprès du KDC)
Pour lire les informations d'un fichier keytab on peux utiliser klist une autre application utilisé pour interagir avec Kerberos sous linux

```
david@inlanfreight.htb@linux01 ~$ klist -k -t /path/to/file.keytab
```

-k : indique à klist qu'on utilise un fichier de type keytab et non le cache habituel
-t : affiche le timestamp date et numéro de version de la clé
Après avoir recolté ces détailles sur la clé (le user a qui elle est, et si elle est encore valid) on peux tenter avec kinit de charger dans notre session un ticket d'authentification valide et ainsi posséder l'identité de l'utilisateur dans tout le reseaux de l'entreprise

```
david@inlanfreight.htb@linux01 ~$ kinit carlos@INLANEFREIGHT.HTB -k
-t /path/to/carlos.keytab
```

Δ kinit est sensible à la casse, les options -k signifie de ne pas demander de mdp mais d'utiliser la clé -t donne le chemin de la clé de chiffrement dans le fichier keytab "ici". On peux executer klist pour s'assurer que le ticket à bien été chargé.
On peux également extraire les hashages d'un keytab avec différents outils comme keytabextract.py, puis les cracker hors ligne, faire du PTH ou forger un ticket...